

Vulnerability Assessment Report

For demo.testfire.net (Altoro Mutual)

Prepared by: Kenny Ntsako Kosa]

Cyber Security Intern - Future Interns

Date: June 26, 2026

Executive Summary

Altoro Mutual's public web application (demo.testfire.net) was assessed using industry-standard passive scanning tools, including Nmap and OWASP ZAP.

The assessment was strictly read-only and conducted ethically, with no active exploitation performed.

The assessment revealed multiple security misconfigurations, primarily related to missing HTTP security headers. The most critical findings include the absence of Content Security Policy (CSP) and Strict-Transport-Security (HSTS), which expose customers to cross-site scripting (XSS) and man-in-the-middle (MITM) attacks.

Additionally, alternative port 8080 was found to be publicly accessible, increasing the organization's attack surface.

Immediate implementation of the recommended security headers and firewall restrictions is strongly advised to significantly reduce the overall risk profile.

Scope & Methodology

Target Website: <http://demo.testfire.net>

Scope of Assessment:

- Public-facing pages only
- Passive analysis (read-only)
- No login bypass, exploitation, or brute force attacks were performed

Tools Used:

- **Nmap** – Port and service discovery
- **OWASP ZAP** – Passive vulnerability scanning
- **Browser DevTools** – Security header inspection

Ethics Statement:

All activities were conducted strictly within the guidelines of ethical security auditing. No active exploitation or Denial-of-Service (DoS) testing was performed.

Findings

#	Finding	Risk	Business Impact	Recommended Fix
1	Missing Content Security Policy (CSP)	High	Attackers can inject malicious scripts into the site, stealing customer session cookies or redirecting users to fake pages.	Implement a strict CSP policy: default-src 'self'
2	Missing Strict-Transport-Security (HSTS)	High	Users on public Wi-Fi can be forced to use unsecured HTTP, allowing attackers to intercept login credentials.	Enable HSTS: Strict-Transport-Security: max-age=31536000; includeSubDomains
3	Missing X-Frame-Options	Medium	The site can be embedded in an invisible iframe on malicious sites, enabling clickjacking attacks where users unknowingly click hidden buttons.	Add header: X-Frame-Options: SAMEORIGIN

5	Cookie without SameSite Attribute	Medium	Cookies are not restricted to the same site, making the application vulnerable to Cross-Site Request Forgery (CSRF) attacks.	Set cookie attribute: SameSite=Strict or SameSite=Lax
6	Exposed Port 8080 (Public Access)	Medium	Alternative ports are often used for admin dashboards, doubling the attack surface for brute-force attacks.	Block port 8080 in the firewall or restrict to internal IPs only.
7	Server Version Disclosure	Low	Revealing the exact server version (Apache-Coyote/1.1) helps attackers find known exploits for that version.	Obfuscate the Server header to hide the exact version.
8	Missing Cache-Control Directives	Low	Sensitive pages may be stored in browser cache, risking data exposure on shared computers.	Add: Cache-Control: no-cache, no-store, must-revalidate

Remediation Roadmap (Priority Order)

Priority 1 – Immediate Action (High Risk)

- Implement Content Security Policy (CSP)
- Enable Strict-Transport-Security (HSTS)
-

Priority 2 – Short-Term Action (Medium Risk)

- Add X-Frame-Options header
- Add X-Content-Type-Options header
- Configure SameSite attribute on all session cookies
- Restrict access to Port 8080 via firewall

Priority 3 – Long-Term Action (Low Risk)

- Hide server version information
- Implement proper Cache-Control headers for sensitive pages

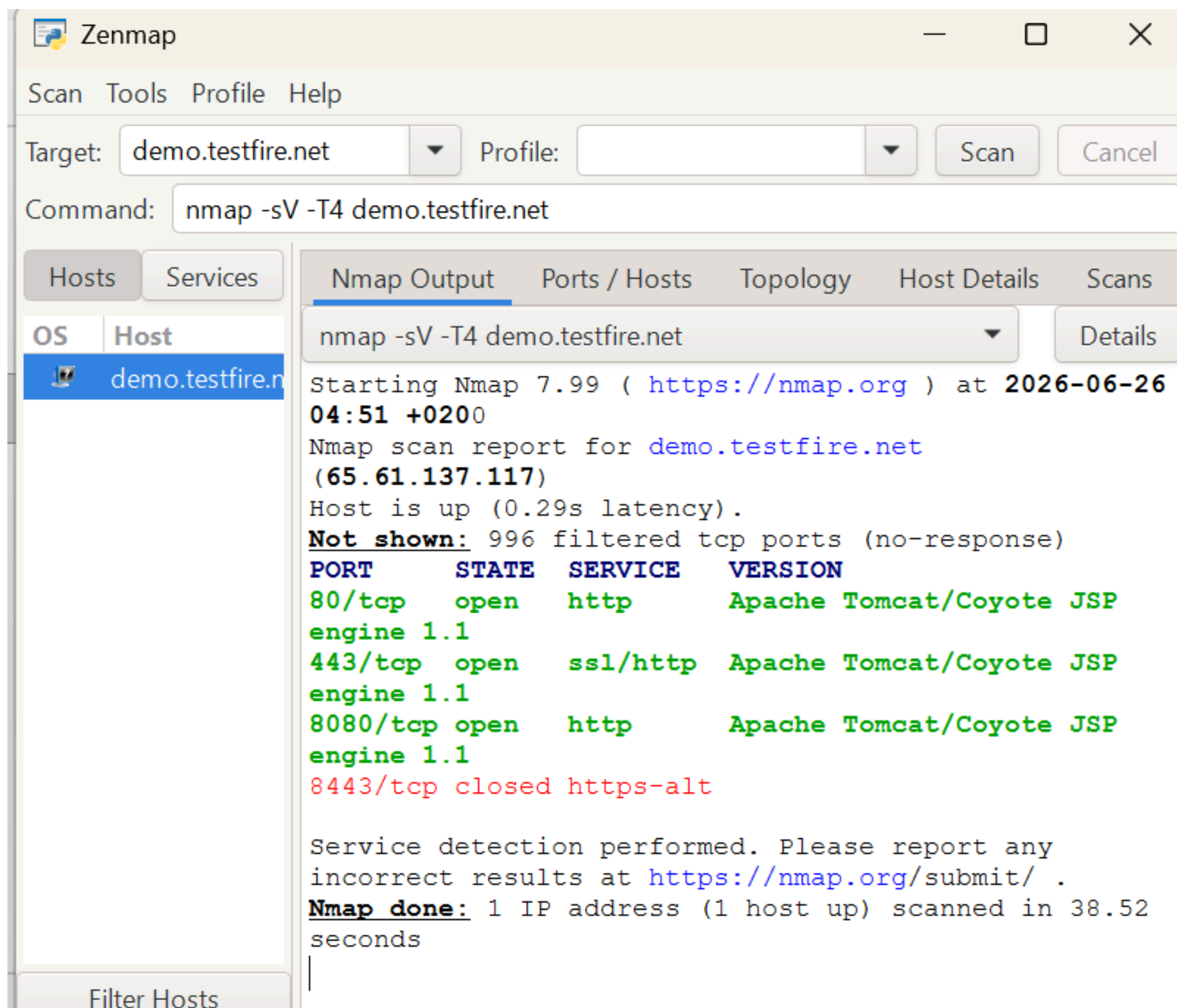


Figure 1: Nmap scan showing open ports (80, 443, 8080) and Apache-Coyote server version disclosure.

← → ↻ Not secure https://demo.testfire.net

Chrome is being controlled by automated test software

Sign In | Contact Us | Feedback | Search

AltoroMutual

DEMO SITE ONLY

ONLINE BANKING LOGIN

PERSONAL

SMALL BUSINESS

INSIDE ALTORO MUTUAL

PERSONAL

- Deposit Product
- Checking
- Loan Products
- Cards
- Investments & Insurance
- Other Services

SMALL BUSINESS

- Deposit Products
- Lending Services
- Cards
- Insurance
- Retirement
- Other Services

Online Banking with FREE Online Bill Pay

No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing

Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a

Business Credit Cards

You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions

Retaining good employees is a

Privacy and Security

The 2000 employees of Altoro Mutual are dedicated to protecting your [privacy](#) and [security](#). We pledge to provide you with the information and resources that you need to help secure your information and keep it confidential. This is our promise.

Win a Samsung Galaxy S10

Network

demo.testfire.net

style.css

logo.gif

header_pic.jpg

home1.jpg

home2.jpg

home3.jpg

gradient.jpg

pf_lock.gif

favicon.ico

General

Request URL: https://demo.testfire.net/

Request Method: GET

Status Code: 200 OK

Remote Address: 127.0.0.1:8080

Referrer Policy: strict-origin-when-cross-origin

Response headers

Content-Length: 9405

Content-Type: text/html; charset=ISO-8859-1

Date: Fri, 26 Jun 2026 03:05:36 GMT

Server: Apache-Coyote/1.1

Request Headers

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-

Figure 2: Browser DevTools revealing missing security headers (X-Frame-Options, HSTS, etc.).

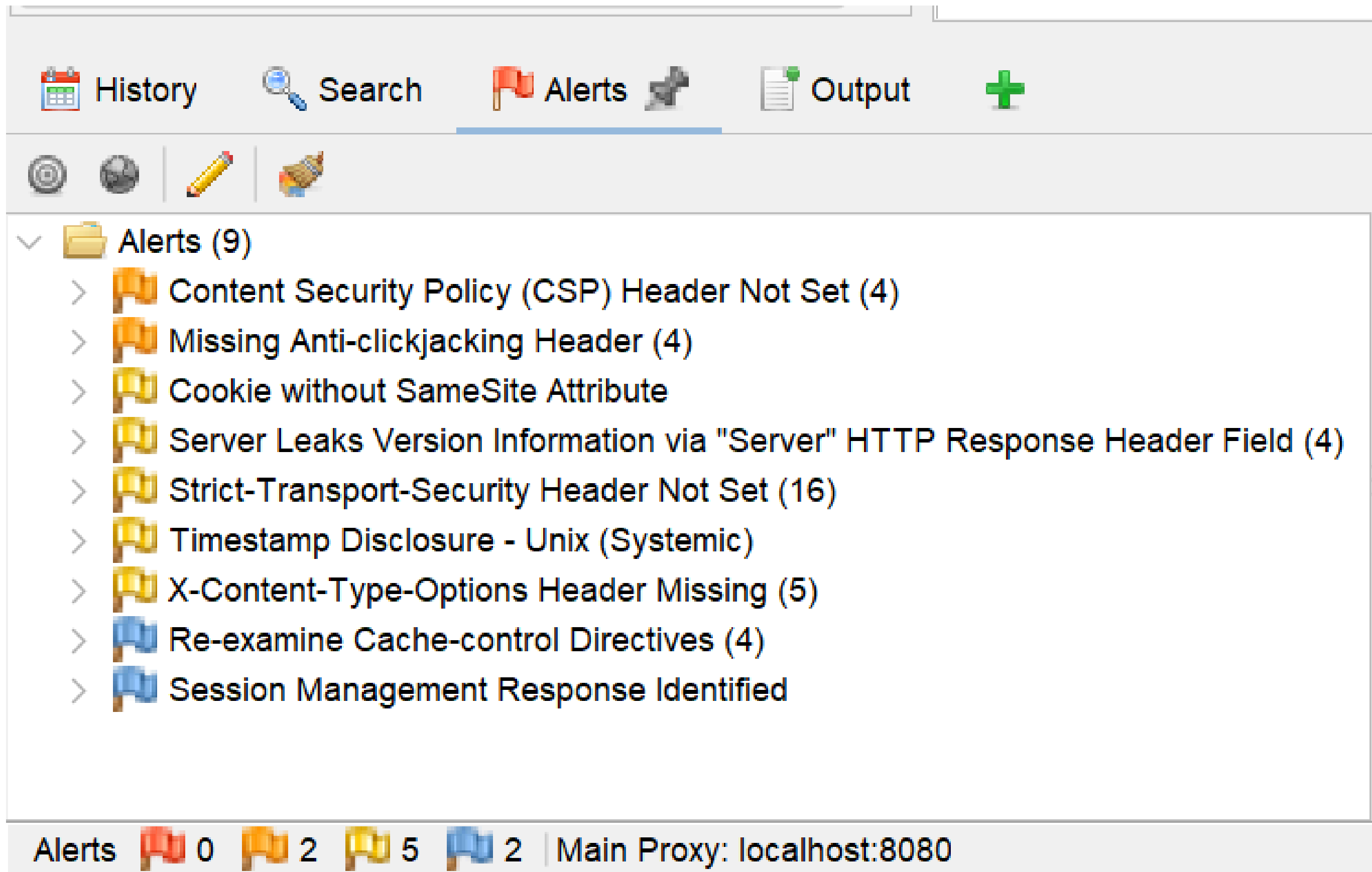


Figure 3: OWASP ZAP passive scan alerts confirming 9 security misconfigurations.

Conclusion

The vulnerability assessment of demo.testfire.net identified 8 security issues, ranging from High to Low risk. The most critical gaps are the complete absence of essential security headers (CSP, HSTS, X-Frame-Options), which are foundational for protecting customers from modern web attacks.

By implementing the recommended remediation steps, starting with the high-priority headers and firewall restrictions, the organization can significantly improve its security posture and protect its customers' sensitive information.

This assessment was conducted ethically and strictly within read-only scope, ensuring no disruption to the live website.